

CYBER SECURE SOLUTIONS

Gestion d'une attaque avancée par ransomware

Type: plan_reponse_ransomware

Date: 3/30/2025

Référence: Gestion de crise cyber

Destinataire: Eddy

****Plan de Réponse au Ransomware****

****Domaine : Gestion de crise cyber****

****Scénario : Gestion d'une attaque avancée par ransomware****

****Niveau de difficulté : Expert****

****Contact : Lorenzo Bertola****

****Destinataire : Eddy****

****Contexte de l'incident****

Le réseau de l'entreprise a subi une attaque par ransomware de type avancé. Plusieurs systèmes critiques ont été chiffrés, incluant les serveurs de fichiers, les bases de données de production et les machines utilisateurs du département financier. Le ransomware utilisé semble être une variante récente, identifiée comme ayant des capacités de propagation rapide via SMB (Server Message Block) et exploitation des vulnérabilités connues des systèmes Windows.

Les attaquants ont laissé une note de rançon spécifiant une exigence de paiement en cryptomonnaie (Bitcoin ou Monero) dans un délai de 72 heures. Le montant de la rançon est élevé (indication dans les fichiers : 10 BTC). La note inclut une adresse de portefeuille et un canal de communication via un service de messagerie chiffrée.

****Première observation :**** Les logs collectés par les systèmes de surveillance montrent une activité inhabituelle 48 heures avant l'incident, incluant des connexions RDP suspectes et des transferts de fichiers volumineux.

****Impact identifié****

- ****Systèmes touchés :****

- Serveur de fichiers partagé (\\corp-server-01\\shared)
- Base de données SQL (version 2019) hébergée sur `sql-prod-01`
- Ordinateurs individuels dans les départements financier et RH (16 machines identifiées à ce jour).

- ****Services affectés :****

- Accès aux données critiques (rapports financiers, données RH, CRM client).
- Services internes dépendants de la base de données (portail interne, système de gestion des commandes).

- **Propagation :**

- Analyse initiale des logs et captures réseau indique que le ransomware s'est propagé via une exploitation de la vulnérabilité MS17-010 (EternalBlue).

Risques associés

1. **Perte de données sensibles :** Risque de fuite ou publication des données chiffrées.
2. **Interruption d'activité :** Opérations bloquées dans plusieurs départements clés.
3. **Réputation et conformité :** Non-respect des obligations réglementaires (ex. RGPD) en cas de divulgation de données personnelles.
4. **Coût financier :** Potentiel paiement de la rançon et coûts de récupération des systèmes.

Chronologie des événements

- **J-2 :** Détection de connexions RDP suspectes sur plusieurs machines.
- **J-1 :** Premiers rapports d'activité inhabituelle (ralentissements sur les serveurs et transferts de fichiers).
- **Jour J (17h30) :** Découverte du ransomware. Plusieurs écrans affichent la note de rançon.
- **Jour J+1 :** Investigation initiale lancée. Confirmation d'impact sur les systèmes critiques par l'équipe SOC.

Ressources disponibles

- **Équipe interne :**
 - SOC (Security Operations Center) en charge de l'analyse des logs et des systèmes compromis.
 - Lorenzo Bertola (Responsable cyber-risques) disponible pour escalade et coordination.
- **Outils techniques :**
 - EDR (Endpoint Detection and Response) installé sur les machines infectées.
 - SIEM (Security Information and Event Management) pour analyse des événements réseau.
 - Sauvegardes incrémentielles disponibles (statut à vérifier).

Points à analyser

1. **Origine de l'infection :** Identifier le vecteur initial (phishing, vulnérabilité exploitée, etc.).
2. **Étendue de l'impact :** Cartographier les systèmes compromis et évaluer la propagation.
3. **Note de rançon :** Examiner la structure du message et ses métadonnées pour retrouver des indices sur les attaquants (ex. identifiants de groupes connus).
4. **Sauvegardes :** Vérifier l'intégrité et la disponibilité des sauvegardes hors ligne.

Prochaines étapes

1. Activer le plan de réponse à incident (PRI) : Prioriser containment, eradication et récupération.
2. Effectuer une analyse approfondie des indicateurs de compromission (IOC) dans le réseau.
3. Déterminer si un paiement est envisageable ou si la restauration des systèmes est faisable sans interaction avec les attaquants.

****Contact principal : Lorenzo Bertola****

****Coordination technique et stratégique : Eddy****

